RELATÓRIO TÉCNICO DE VULNERABILIDADES

CVEs recentes do Python

Avisos da Python Software Foundation: agosto a outubro de 2026

Inclui CVE-2026-19445 (ssl, CVSS 4.0 = 9.2) e o aviso crítico do certifi (emSign)

Data de referência: 23 de outubro de 2026
Escopo: CPython 3.10 a 3.15 — 9 CVEs + 1 aviso do certifi (avisos de 18/08 a 22/10/2026)
Fontes oficiais: lista security-announce@python.org (PSRT), registros da PSF como CNA, repositório python/cpython e devguide.python.org

Documento de estudo. Notas CVSS 4.0, CWE e versões afetadas vêm dos registros publicados pela PSF (CNA) e replicados na NVD. Confirme sempre no registro da CVE (cve.org) e no aviso original antes de agir em produção.

Sumário

1. Sumário executivo **3**

2. Contexto: como o Python trata vulnerabilidades **4**

3. Módulo ssl e TLS **5**

3.1 CVE-2026-19445 — use-after-free no servidor TLS via sni_callback . . . 5

3.2 CVE-2026-19553 — wrap_bio() pulava a verificação de hostname . . . 5

4. Módulo tarfile: filtros de extração burlados **7**

4.1 CVE-2026-82049 — hard link para symlink burla os filtros . . . 7

4.2 CVE-2026-114583 — bypass do tar_filter com symlinks de nome vazio . . . 8

4.3 CVE-2026-19672 — diretórios vazios criados fora do destino . . . 8

4.4 CVE-2026-87910 — filtro customizado ignorado no fallback de hard link . . . 9

5. Outros módulos **10**

5.1 CVE-2026-15806 — urllib enviava credenciais HTTPS por HTTP . . . 10

5.2 CVE-2026-12345 — corrida na limpeza do TemporaryDirectory . . . 10

5.3 CVE-2026-15310 — esgotamento de memória no zipfile . . . 11

6. certifi: remoção das raízes emSign (crítico) **11**

7. Recomendações práticas **13**

Fontes de pesquisa **13**

1. Sumário executivo

Diferente da Microsoft e da Oracle, o Python não tem um “dia de patch”. O **Python Security Response Team (PSRT)** corrige as falhas no repositório **python/cpython**, a **Python Software Foundation (PSF)** — que é a autoridade emissora de CVEs (CNA) do projeto — publica o registro da CVE, e o aviso sai na lista oficial **security-announce@python.org**. As correções chegam nas versões seguintes de cada ramo.

Este relatório cobre **todos os avisos publicados nessa lista entre 18/08 e 22/10/2026**: 9 CVEs do CPython e 1 aviso crítico do pacote **certifi**. Para contexto, também cita a CVE-2026-7774 (junho), da qual uma das falhas de outubro é a continuação.

Principais conclusões

- **CVE-2026-19445 (ssl) é a mais grave: CVSS 4.0 = 9,2.** Um cliente TLS remoto, sem autenticação, pode derrubar ou explorar um **servidor** Python que troca de SSLContext no `sni_callback` (use-after-free).
- **CVE-2026-19553 (ssl, 7,6):** `SSLContext.wrap_bio()` — usado pelo asyncio — podia **pular a verificação de hostname em silêncio** quando o `server_hostname` não era informado.
- **Cinco das nove CVEs estão no** `tarfile`: os filtros de extração criados em 2023 contra path traversal continuam sendo burlados (links simbólicos, hard links, caminhos com `..`). Extrair arquivos .tar de origem não confiável continua arriscado.
- **certifi — aviso crítico:** a versão 2026.10.18/19 remove as raízes **emSign** (eMudhra), cujas intermediárias foram revogadas por comprometimento de chave. É o mesmo incidente que motivou correções no Node.js e no Java esta semana.
- **Python 3.10 chegou ao fim de vida em 01/10/2026**; a 3.10.22 foi a última versão. A 3.15 foi lançada em 09/10/2026.
- **Versões a usar hoje:** 3.15.1, 3.14.9 e 3.13.17 (21/10), 3.12.15 (30/09) e 3.11.17 (01/10). Duas falhas do tarfile (CVE-2026-114583 e CVE-2026-19672) têm correção no ramo principal, mas o registro oficial ainda as marca como afetando todas as versões anteriores à 3.16.

Visão geral

CVE / aviso	Módulo	Tipo	CVSS 4.0	Publicado
CVE-2026-19445	ssl	Use-after-free no servidor TLS	9.2 Crítica	30/09
CVE-2026-19553	ssl / asyncio	Verificação de hostname pulada	7.6 Alta	30/09
CVE-2026-82049	tarfile	Bypass de filtro (hard link → symlink)	8.4 Alta	14/09
CVE-2026-114583	tarfile	Bypass do tar_filter → escrita fora do destino	6.9 Média	22/10
CVE-2026-19672	tarfile	Diretórios criados fora do destino	6.3 Média	19/08
CVE-2026-87910	tarfile	Filtro customizado ignorado (fallback de hard link)	5.7 Média	11/09
CVE-2026-15806	urllib.request	Credenciais HTTPS enviadas por HTTP	6.0 Média	18/08
CVE-2026-12345	tempfile	Corrida na limpeza apaga arquivos externos	5.9 Média	29/09
CVE-2026-15310	zipfile	Esgotamento de memória (bzip2/LZMA/zstd)	2.1 Baixa	25/08
GHSA-6q48-6c7w-9gw2	certifi (PyPI)	Remoção das raízes emSign	Crítica (sem CVSS)	20/10

A PSF pontua em CVSS 4.0, que dá notas diferentes do CVSS 3.1 usado nos relatórios da Microsoft e da Oracle — compare com cuidado. Todas as datas são de 2026.

2. Contexto: como o Python trata vulnerabilidades

- **PSRT:** recebe relatos privados (security@python.org) sobre o CPython e o pip. Não há programa de recompensa (bug bounty) nem aceita relatos que afetem só versões de pré-lançamento.
- **PSF como CNA:** emite e mantém os registros das CVEs; correções de registro vão para cna@python.org.
- **Onde acompanhar:** a lista security-announce@python.org (com arquivo público) e o banco de avisos em formato OSV no GitHub (psf/advisory-database), lido por ferramentas como pip-audit e osv-scanner.
- **Distribuições Linux** (Debian, Ubuntu, RHEL) aplicam as correções no pacote delas, às vezes sem mudar o número da versão — confira o changelog do pacote.

Ciclo de vida dos ramos (devguide.python.org)

Ramo	Situação	Lançamento	Fim de vida	Versão atual
3.15	bugfix	09/10/2026	out/2031	3.15.1 (21/10)
3.14	bugfix	07/10/2025	out/2030	3.14.9 (21/10)
3.13	security (só correções de segurança)	07/10/2024	out/2029	3.13.17 (21/10)
3.12	security	02/10/2023	out/2028	3.12.15 (30/09)
3.11	security	24/10/2022	out/2027	3.11.17 (01/10)
3.10	**fim de vida**	2021	01/10/2026	3.10.22 (última)
3.9 e anteriores	fim de vida	—	até 31/10/2025	—

Ramos em “security” recebem apenas correções de segurança, e só em código-fonte — o instalador para Windows/macOS não é mais publicado. Quem instala pelo python.org nesses ramos precisa compilar ou usar o Python do sistema/distribuição.

Glossário rápido

Termo	Significado
Filtros de extração do tarfile	Desde a PEP 706 (2023), `tarfile.extractall(filter=...)` aceita `'data'` (mais restrito), `'tar'` ou `'fully_trusted'`. No Python 3.14 o padrão passou a ser `'data'`. Os filtros bloqueiam caminhos absolutos, `..` e links que apontam para fora do destino.
Symlink / hard link	Link simbólico aponta para um caminho; hard link é outro nome para o mesmo arquivo. Combinações dos dois, ou nomes vazios, confundem a checagem de contenção.
SNI / sni_callback	No TLS, o cliente informa o nome do site; o `sni_callback` permite ao servidor escolher outro `SSLContext` (outro certificado) para aquela conexão.
wrap_bio()	Cria um objeto TLS sobre buffers em memória (MemoryBIO) em vez de um socket — é o que o asyncio usa internamente.
CVSS 4.0 (AT, VC/VI/VA, SC/SI/SA)	AT = requisitos de ataque; VC/VI/VA = impacto no sistema vulnerável; SC/SI/SA = impacto em sistemas subsequentes.
certifi	Pacote do PyPI com a lista de autoridades certificadoras da Mozilla, usado pelo requests, pip e boa parte do ecossistema no lugar do repositório do sistema.

3. Módulo ssl e TLS

3.1 CVE-2026-19445 — use-after-free no servidor TLS via sni_callback

CVE-2026-19445	CRÍTICA · CVSS 4.0 9.2
Título oficial	Use-after-free of a server-side SSLContext when sni_callback switches contexts
Vetor CVSS 4.0	`AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N`
Fraqueza (CWE)	CWE-416: uso após liberação
Versões afetadas	< 3.10.22 · 3.11.0–<3.11.17 · 3.12.0–<3.12.15 · 3.13.0–<3.13.16 · 3.14.0–<3.14.8 · 3.15.0a1–<3.15.0rc3
Corrigido em	3.10.22 · 3.11.17 · 3.12.15 · 3.13.16 · 3.14.8 · 3.15.0 (ou posteriores)
Aviso	30/09/2026 — Seth Larson (PSF)
Correção	Issue #156293 · PR #158504

O que identifica

Num **servidor** TLS escrito em Python, o `sni_callback` pode trocar `SSLSocket.context` por outro `SSLContext` para servir um certificado diferente conforme o nome pedido. Se nada mais no programa mantiver uma referência ao contexto **original**, o coletor de lixo o libera enquanto o código em C do módulo ssl ainda aponta para ele — um **use-after-free**.

Um cliente TLS remoto, **sem autenticação**, consegue provocar a condição apenas negociando o handshake. São afetados principalmente servidores que criam um `SSLContext` por conexão ou que o substituem com conexões abertas. Servidores que embrulham o socket de escuta com o contexto (o padrão) **não** são afetados, nem clientes TLS.

Impacto

No mínimo, queda do servidor (DoS). No pior caso, chamada por um ponteiro liberado, que pode virar execução de código — por isso a confidencialidade e a integridade altas no vetor. A complexidade é alta e depende do padrão de código.

Correção e mitigação

Atualizar o CPython. Contorno oficial: manter uma referência a todo `SSLContext` que define `sni_callback` durante toda a vida do servidor (por exemplo, guardá-los numa lista global).

3.2 CVE-2026-19553 — wrap_bio() pulava a verificação de hostname

CVE-2026-19553	ALTA · CVSS 4.0 7.6
Título oficial	SSLContext.wrap_bio() missing validation of server_hostname parameter
Vetor CVSS 4.0	`AV:N/AC:L/AT:P/PR:N/UI:P/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`
Fraqueza (CWE)	CWE-297: validação imprópria de certificado com hostname divergente
Versões afetadas	< 3.10.22 · 3.11.0–<3.11.17 · 3.12.0–<3.12.15 · 3.13.0–<3.13.16 · 3.14.0–<3.14.8 · 3.15.0a1–<3.15.0rc3
Corrigido em	3.10.22 · 3.11.17 · 3.12.15 · 3.13.16 · 3.14.8 · 3.15.0 (ou posteriores)
Aviso	30/09/2026 — Seth Larson (PSF)
Correção	Issue #156793 · PR #158503

O que identifica

Com `check_hostname=True` (o padrão de `ssl.create_default_context()`), `wrap_socket()` exige um `server_hostname` e lança `ValueError` se ele faltar. Já `wrap_bio()` não fazia essa checagem: sem o argumento, o handshake aceitava **qualquer certificado válido**, de qualquer domínio, e a verificação parecia ter dado certo.

Como o asyncio usa `wrap_bio()` por baixo, `asyncio.create_connection(..., ssl=ctx)` e `loop.start_tls()` sem `server_hostname` (por exemplo, conectando por IP) ficavam expostos.

Impacto

Um atacante em posição de interceptação apresenta um certificado legítimo de **outro** domínio e o cliente aceita, permitindo ler e alterar o tráfego (man-in-the-middle).

Correção e mitigação

Atualizar — após a correção, a chamada sem `server_hostname` lança `ValueError`, o que pode “quebrar” código que antes funcionava por engano. Sem atualizar: sempre passar um `server_hostname` válido para `wrap_bio()`, `asyncio.create_connection()` e `loop.start_tls()`.

```
# Vulnerável (antes da correção): verificação de hostname pulada sem aviso
reader, writer = await asyncio.open_connection('203.0.113.10', 443, ssl=ctx)

# Correto: informe o nome que o certificado deve conter
reader, writer = await asyncio.open_connection('203.0.113.10', 443, ssl=ctx,
                                               server_hostname='api.exemplo.com')
```

4. Módulo tarfile: filtros de extração burlados

Em 2023 (PEP 706), o Python criou filtros para tornar `tarfile.extractall()` seguro contra arquivos maliciosos, depois de anos de ataques de path traversal (CVE-2007-4559). Desde então, pesquisadores encontram formas cada vez mais sutis de burlá-los. Só neste período foram cinco CVEs, mais a CVE-2026-7774 de junho:

CVE	Filtro burlado	Truque usado	Efeito
CVE-2026-7774 (jun)	data	Symlinks com nome vazio ou com cara de diretório	Escrita fora do destino
CVE-2026-114583	tar	Mesmo truque da 7774, no filtro “tar”	Escrita fora do destino
CVE-2026-82049	data e tar	Hard link que aponta para um symlink	Altera permissões/mtime ou expõe conteúdo de arquivo externo
CVE-2026-19672	data e tar	Nome que sai e volta: ../evil/../dest/sub/file	Cria diretórios vazios fora do destino
CVE-2026-87910	filtro customizado	Fallback de hard link ignora o retorno None do filtro	Membro rejeitado é extraído mesmo assim

4.1 CVE-2026-82049 — hard link para symlink burla os filtros

CVE-2026-82049	**ALTA · CVSS 4.0 8.4**
Título oficial	tarfile extraction filters allow file modification and content disclosure via hard link to symlink
Vetor CVSS 4.0	`AV:L/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`
Fraqueza (CWE)	CWE-59: resolução imprópria de link
Versões afetadas	< 3.10.22 · 3.11.0–<3.11.17 · 3.12.0–<3.12.15 · 3.13.0–<3.13.16 · 3.14.0a1–<3.14.0b1 (3.14 final não afetada)
Corrigido em	3.10.22 · 3.11.17 · 3.12.15 · 3.13.16
Aviso	14/09/2026 — Stan Ulbrych
Correção	Issue #157190 · PRs #157191/#157192

O que identifica

O arquivo .tar traz um symlink e, depois, um **hard link apontando para esse symlink**. Os filtros `'data'` e `'tar'` validavam cada membro isoladamente e não percebiam que, na extração, o hard link acabava resolvendo para um arquivo **fora** do diretório de destino.

Impacto

Ao extrair, o Python pode mudar as permissões ou a data de modificação de um arquivo externo (por exemplo, tornar um arquivo de configuração gravável) ou copiar o conteúdo de um arquivo externo para dentro da árvore extraída — que pode depois ser devolvida ao atacante (ex.: um serviço que extrai e reempacota uploads).

Correção e mitigação

Atualizar. Paliativo: extrair arquivos não confiáveis num diretório temporário aleatório, com um usuário sem privilégios, ou rejeitar previamente arquivos que contenham links (`member.issym() or member.islnk()`).

4.2 CVE-2026-114583 — bypass do tar_filter com symlinks de nome vazio

CVE-2026-114583	MÉDIA · CVSS 4.0 6.9
Título oficial	tarfile.tar_filter path traversal bypass allows writing outside the extraction directory
Vetor CVSS 4.0	`AV:L/AC:L/AT:N/PR:N/UI:N/VC:N/VI:H/VA:N/SC:N/SI:N/SA:N`
Fraqueza (CWE)	Não informada (path traversal)
Versões afetadas	Todas anteriores à 3.16.0, segundo o registro (inclui 3.15.1)
Corrigido em	Ramo principal (commits de 22/10/2026); verifique os backports nas próximas versões de manutenção
Aviso	22/10/2026 — Stan Ulbrych
Correção	Issue #160097 · PR #160098

O que identifica

É a contrapartida, no filtro `'tar'`, da CVE-2026-7774 (corrigida em junho no filtro `'data'`). Entradas de link com nomes vazios ou parecidos com diretórios (ex.: um symlink chamado `''` ou `'dir/'`) redirecionam os membros seguintes para fora do destino.

Impacto

Um arquivo malicioso extraído com `extractall(filter='tar')` grava arquivos fora do destino — por exemplo, sobrescrevendo scripts ou configurações — limitado às permissões do processo.

Correção e mitigação

Usar `filter='data'` (mais restrito e já corrigido na CVE-2026-7774) em vez de `'tar'`; extrair com usuário sem privilégios; atualizar assim que as versões com a correção forem publicadas.

4.3 CVE-2026-19672 — diretórios vazios criados fora do destino

CVE-2026-19672	MÉDIA · CVSS 4.0 6.3
Título oficial	tarfile extraction filter bypass allows creation of directories outside the destination
Vetor CVSS 4.0	`AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N`
Fraqueza (CWE)	CWE-22: path traversal
Versões afetadas	Todas anteriores à 3.16.0, segundo o registro; só em POSIX (Linux/macOS)
Corrigido em	PR #156000 (ramo principal)
Aviso	19/08/2026 — Stan Ulbrych
Correção	PR #156000

O que identifica

Um membro chamado `../evil/../dest/sub/file` “sai” do destino e “volta” para ele. A checagem de contenção usa o caminho já resolvido (que fica dentro de `dest`), mas os diretórios intermediários são criados a partir do nome literal — então `../evil` é criado fora.

Impacto

Só diretórios **vazios** são criados fora; o conteúdo é extraído dentro do destino. O atacante precisa saber o nome da pasta de destino. No Windows não acontece, porque o `..` é resolvido antes de chegar ao sistema de arquivos. O impacto é baixo (SI:L), mas pode ser usado para preparar outros ataques.

Correção e mitigação

Extrair em diretório de nome aleatório (`tempfile.mkdtemp()`) torna o ataque inviável. Atualizar quando disponível.

4.4 CVE-2026-87910 — filtro customizado ignorado no fallback de hard link

CVE-2026-87910	MÉDIA · CVSS 4.0 5.7
Título oficial	tarfile hardlink fallback ignores custom extraction filter rejection via None
Vetor CVSS 4.0	`AV:N/AC:L/AT:P/PR:L/UI:A/VC:N/VI:H/VA:N/SC:N/SI:N/SA:N`
Fraqueza (CWE)	CWE-22 e CWE-59
Versões afetadas	Todas anteriores à 3.15.0
Corrigido em	3.15.0
Aviso	11/09/2026 — Petr Viktorin
Correção	Issue #157265 · PR #157266

O que identifica

Quando o sistema de arquivos não suporta links (ex.: alguns volumes no Windows ou FAT), o tarfile extrai uma cópia do arquivo-alvo no lugar do link. Nesse caminho, a função de filtro é chamada **duas vezes**, e o retorno `None` (que significa “rejeitar este membro”) de uma delas era ignorado.

Impacto

Aplicações que escrevem o próprio filtro de segurança acreditam ter bloqueado um membro, mas ele é extraído mesmo assim.

Correção e mitigação

Atualizar para 3.15. Em versões anteriores, validar os membros antes da extração (iterando `getmembers()`) em vez de confiar só no filtro.

5. Outros módulos

5.1 CVE-2026-15806 — urllib enviava credenciais HTTPS por HTTP

CVE-2026-15806	MÉDIA · CVSS 4.0 6.0
Título oficial	urllib.request.HTTPPasswordMgr credentials for one URL scheme sent over another scheme
Vetor CVSS 4.0	`AV:N/AC:H/AT:P/PR:N/UI:P/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N`
Fraqueza (CWE)	CWE-319 (texto claro) e CWE-522 (credenciais mal protegidas)
Versões afetadas	< 3.10.22 · 3.11.0–<3.11.17 · 3.12.0–<3.12.15 · 3.13.0–<3.13.16 · 3.14.0–<3.14.8 · 3.15.0a1–<3.15.0rc2
Corrigido em	3.10.22 · 3.11.17 · 3.12.15 · 3.13.16 · 3.14.8 · 3.15.0 (ou posteriores)
Aviso	18/08/2026 — Kirill Podoprigora
Correção	Issue #155694 · PR #155696
SSVC (CISA)	Exploração: há prova de conceito (PoC); não automatizável

O que identifica

`HTTPPasswordMgr` (e as subclasses `HTTPPasswordMgrWithDefaultRealm` e `HTTPPasswordMgrWithPriorAuth`) comparava apenas host e caminho ao escolher a credencial, **ignorando o esquema**. Credenciais cadastradas para `https://host` eram enviadas também para `http://host`, e vice-versa.

Impacto

Um atacante que force um redirecionamento ou downgrade para HTTP — ou que esteja no caminho da rede — captura usuário e senha em texto claro. A CISA registra que existe prova de conceito.

Correção e mitigação

Atualizar: a correspondência passa a respeitar o esquema (credenciais cadastradas só com host, sem esquema, continuam valendo para qualquer um, por compatibilidade). Até lá: nunca seguir redirecionamentos para `http://` em hosts com credenciais.

5.2 CVE-2026-12345 — corrida na limpeza do TemporaryDirectory

CVE-2026-12345	MÉDIA · CVSS 4.0 5.9
Título oficial	Race condition in tempfile.TemporaryDirectory cleanup allows deleting files outside the temporary directory
Vetor CVSS 4.0	`AV:L/AC:L/AT:P/PR:N/UI:N/VC:N/VI:H/VA:H/SC:N/SI:N/SA:N`
Fraqueza (CWE)	CWE-59
Versões afetadas	< 3.12.15 e 3.15.0a1–<3.15.0rc3 (conforme o registro da CNA)
Corrigido em	3.12.15 · 3.15.0 (consulte o registro para os demais ramos)
Aviso	29/09/2026 — Stan Ulbrych
Correção	Issue #157579 · PR #157580

O que identifica

Ao sair de um `with tempfile.TemporaryDirectory()`, o Python apaga a árvore e, se encontra arquivos sem permissão, ajusta permissões e flags para conseguir apagar. Um atacante local que consiga mexer na árvore **durante** essa limpeza troca um diretório por um link simbólico, e a limpeza passa a agir fora do diretório temporário.

Impacto

Arquivos fora do temporário podem ser apagados ou ter permissões e flags redefinidas, com os privilégios do processo que limpa — grave se esse processo roda como root. Plataformas onde `shutil.rmtree.avoids_symlink_attacks` é `False` continuam afetadas, e a redefinição de flags pode ocorrer em todas.

Correção e mitigação

Atualizar. Evitar criar diretórios temporários em locais graváveis por outros usuários com processos privilegiados; conferir `shutil.rmtree.avoids_symlink_attacks` na plataforma.

5.3 CVE-2026-15310 — esgotamento de memória no zipfile

CVE-2026-15310	BAIXA · CVSS 4.0 2.1
Título oficial	Memory exhaustion in zipfile in bzip2/LZMA/Zstandard decompression
Vetor CVSS 4.0	`AV:N/AC:L/AT:P/PR:N/UI:A/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N`
Fraqueza (CWE)	CWE-400: consumo descontrolado de recursos
Versões afetadas	Todas anteriores à 3.15.0rc2
Corrigido em	3.15.0 (por ser de gravidade baixa, o registro não lista backport)
Aviso	25/08/2026 — Petr Viktorin
Correção	Issue #156002 · PR #156003

O que identifica

Ao descompactar membros de um ZIP comprimidos com bzip2, LZMA ou Zstandard, o `zipfile` usava um tamanho informado pelo próprio arquivo para pré-alocar memória. Um ZIP preparado declara um tamanho enorme.

Impacto

Negação de serviço por falta de memória em serviços que abrem ZIPs enviados por usuários. A CISA classifica a exploração como “none”.

Correção e mitigação

Atualizar para 3.15. Em versões anteriores, limitar memória do processo/contêiner e verificar `ZipInfo.file_size` antes de ler os membros.

6. certifi: remoção das raízes emSign (crítico)

GHSA-6q48-6c7w-9gw2	CRÍTICA · sem CVSS / sem CVE
Título oficial	Removal of emSign root certificate
Pacote	certifi (PyPI) — mantido pela comunidade e divulgado pela PSF na lista security-announce
Versões afetadas	>= 2019.03.09
Corrigido em	2026.10.18 segundo o GitHub Advisory; o anúncio da PSF cita 2026.10.19 — use a mais recente
Aviso	20/10/2026 — Seth Larson (PSF)

O que identifica

As raízes da autoridade certificadora **emSign** (do grupo eMudhra) têm intermediárias revogadas por **comprometimento de chave**. Quem possui uma chave de CA comprometida pode emitir certificados válidos para qualquer domínio. O certifi é a lista de CAs usada por `requests`, `pip`, `httpx` e grande parte do ecossistema; enquanto ele confiar na emSign, essas bibliotecas aceitariam certificados falsos.

É o mesmo incidente tratado na CVE-2026-91403 do Java (9,1) e na atualização de CAs do Node.js de 21/10/2026.

Correção

- Atualizar: `pip install -U certifi` e conferir com `python -c "import certifi; print(certifi.__version__)"`.
- **Reconstruir imagens de contêiner**: o certifi fica “congelado” dentro da imagem e não se atualiza sozinho.
- Ambientes que usam o repositório de CAs do sistema (`truststore`, Python de distribuição Linux) dependem da atualização do pacote `ca-certificates` do sistema.

7. Recomendações práticas

Para o suporte técnico

- Descobrir a versão: `python3 --version` (ou `py -0p` no Windows, que lista todas as instaladas). Em servidores, verifique o Python do **serviço** (virtualenv, contêiner) e não só o do terminal.
- Atualizar para 3.15.1, 3.14.9, 3.13.17, 3.12.15 ou 3.11.17; em Linux, preferir o pacote corrigido da distribuição. Reiniciar o serviço depois.
- Python 3.10 ou anterior: planejar migração — não há mais correções da PSF.
- Atualizar o certifi em todos os virtualenvs e reconstruir imagens Docker (`docker build --pull --no-cache`).
- Rodar `pip-audit` ou `osv-scanner` nos projetos: eles leem o banco OSV da PSF e apontam pacotes vulneráveis como o certifi. Para o próprio interpretador, verifique a versão manualmente ou com o scanner de imagens (Trivy, Grype).

Para quem desenvolve

- **Extração de arquivos:** sempre `extractall(path, filter='data')`, num diretório aleatório, com usuário sem privilégios. Para arquivos não confiáveis, considere rejeitar links e dispositivos antes de extrair.
- **TLS:** use `ssl.create_default_context()`, sempre informe `server_hostname` no asyncio e nunca use `verify=False` ou `CERT_NONE` como contorno.
- **Servidores TLS com SNI:** mantenha referências a todos os `SSLContext` usados no `sni_callback` (contorno da CVE-2026-19445).
- **Credenciais HTTP:** cadastre-as sempre com o esquema `https://` e bloqueie redirecionamentos para HTTP.
- **Uploads compactados:** limite o tamanho e a memória antes de descompactar ZIPs e TARs.

Prioridade

Prioridade	O quê
1 — imediato	certifi em todos os ambientes; servidores TLS em Python que usam sni_callback (CVE-2026-19445).
2 — esta semana	Clientes asyncio/TLS (CVE-2026-19553) e serviços que extraem .tar enviados por usuários (82049, 114583).
3 — janela normal	Demais CVEs; migração de ambientes com Python 3.10 ou anterior.

Fontes de pesquisa

Consultadas em 23/10/2026. Os anúncios da lista security-announce e os registros da PSF como CNA são as fontes primárias; os registros foram lidos pela API pública da NVD, que replica o texto e a nota CVSS da PSF.

Python Software Foundation (oficiais)

[1] Python Security — política do PSRT
https://www.python.org/dev/security/

[2] Lista security-announce@python.org (arquivo)
https://mail.python.org/archives/list/security-announce@python.org/latest

[3] Aviso CVE-2026-114583 (tarfile.tar_filter)
https://mail.python.org/archives/list/security-announce@python.org/thread/43JOWPRAV5DI3VZ4FUEUAZOHCATXXOCK/

[4] Aviso GHSA-6q48-6c7w-9gw2 (certifi / emSign)
https://mail.python.org/archives/list/security-announce@python.org/thread/LSEJ6DOJPIHHNNRS43GROPIH2EPJRUDS/

[5] Aviso CVE-2026-19445 (ssl, sni_callback)
https://mail.python.org/archives/list/security-announce@python.org/thread/QMQIUQB6WGGC3MI7I3WKQXOYOBDSPPS3/

[6] Aviso CVE-2026-19553 (ssl, wrap_bio)
https://mail.python.org/archives/list/security-announce@python.org/thread/QNZRG3YOAMTHDCMVCICXGY6YEFPY2VDL/

[7] Aviso CVE-2026-12345 (tempfile)
https://mail.python.org/archives/list/security-announce@python.org/thread/WBHGJXKKLB7X3ZJF7NYE6M65DCUWW6QT/

[8] Aviso CVE-2026-82049 (tarfile, hard link)
https://mail.python.org/archives/list/security-announce@python.org/thread/EFJWGAZJA56AKSBR2WHMHQZO7RRLZPRH/

[9] Aviso CVE-2026-87910 (tarfile, fallback)
https://mail.python.org/archives/list/security-announce@python.org/thread/57TBTLL2W6APMZR3A25B2YV7GL3EPTDJ/

[10] Aviso CVE-2026-15310 (zipfile)
https://mail.python.org/archives/list/security-announce@python.org/thread/YUHXURX2WZGKGNA4ANYBQS2VZRYQ5JNK/

[11] Aviso CVE-2026-19672 (tarfile, diretórios)
https://mail.python.org/archives/list/security-announce@python.org/thread/J2WT2ALRWEXQJOB3C7Q2HYWUXP3CINWO/

[12] Aviso CVE-2026-15806 (urllib)
https://mail.python.org/archives/list/security-announce@python.org/thread/3OKPE5S75KDNA7FY7AI3PL2MXM2X5RB3/

[13] Aviso CVE-2026-7774 (tarfile.data_filter, junho)
https://mail.python.org/archives/list/security-announce@python.org/thread/4FU62L2M6RMMHT2QPGQNPEHHUND7CEX5/

[14] Python Developer's Guide — Status of Python versions
https://devguide.python.org/versions/

[15] python.org — Downloads
https://www.python.org/downloads/

Registros das CVEs (dados da CNA PSF)

[16] NVD — CVE-2026-19445
https://nvd.nist.gov/vuln/detail/CVE-2026-19445

[17] NVD — CVE-2026-19553
https://nvd.nist.gov/vuln/detail/CVE-2026-19553

[18] NVD — CVE-2026-82049
https://nvd.nist.gov/vuln/detail/CVE-2026-82049

[19] NVD — CVE-2026-114583
https://nvd.nist.gov/vuln/detail/CVE-2026-114583

[20] NVD — CVE-2026-19672
https://nvd.nist.gov/vuln/detail/CVE-2026-19672

[21] NVD — CVE-2026-87910
https://nvd.nist.gov/vuln/detail/CVE-2026-87910

[22] NVD — CVE-2026-15806
https://nvd.nist.gov/vuln/detail/CVE-2026-15806

[23] NVD — CVE-2026-12345
https://nvd.nist.gov/vuln/detail/CVE-2026-12345

[24] NVD — CVE-2026-15310
https://nvd.nist.gov/vuln/detail/CVE-2026-15310

[25] NVD — CVE-2026-7774
https://nvd.nist.gov/vuln/detail/CVE-2026-7774

Outros

[26] certifi — GitHub Security Advisory GHSA-6q48-6c7w-9gw2
https://github.com/certifi/python-certifi/security/advisories/GHSA-6q48-6c7w-9gw2

[27] Repositório python/cpython (issues e PRs citados)
https://github.com/python/cpython